

Decision Rationale: How the Cyber Protection Policy Was Built

This document explains the reasoning behind the Cyber Protection Policy I drafted for Corgi: who it is for, how its numbers were set, what it covers and leaves out, and the trade-offs I accepted. It follows the order in which I made the decisions. Each step answers one question, and each answer sets part of the policy.

A note on numbers. The policy is a specimen, not a Corgi product, and Cedar Ridge is fictional. Market statistics come from the published sources listed at the end, with links where the source is public. At-Bay figures come from the full 2026 InsurSec Report. Premiums, limits and loss estimates for Cedar Ridge are my own illustrative judgments, and the arithmetic is shown so each can be challenged.

Summary

What the policy is for. It keeps a small or mid-sized business open and solvent after a cyber event. It pays the losses the business can't absorb, pays them fast enough to keep it running, and leaves the small, predictable costs with the business. Every term had to serve that purpose, or protect the insurer's ability to keep offering it (by limiting moral hazard, accumulation or what the law forbids).

Who it's for. U.S. businesses with \$1M–\$50M in revenue, such as accounting firms, clinics, agencies, retailers and light manufacturers. In my view, most buy cyber insurance to survive ransomware and fraud, and many have no broker or in-house IT team to guide them. The sample policyholder is Cedar Ridge Accounting Group, a Denver CPA firm with \$8.5M revenue and 62 staff that runs payroll for 40 clients.

The five decisions that matter most:

1. **The losses that hit small and mid-sized businesses most are core coverages.** Breach response, ransomware, downtime and payment fraud are in the core. Rarer or systemic risks are priced options.
2. **Numbers come from how these businesses lose money.** The retention is set at what a business can absorb; the limit at the worst realistic single event. For Cedar Ridge that means a \$2M limit rather than the \$1M base.
3. **Payment fraud is written around how firms that move money actually get robbed.** It covers partners, the bank and client accounts, because U.S. courts have repeatedly denied these losses under narrower wording.
4. **Security affects price, not whether you're covered.** Only three disclosed terms can cut a payment for security reasons, and each applies only if the gap mattered to the loss. Losing a credit can raise the retention.
5. **Cash timing is treated as a coverage issue.** Seven days of free first response, a firm 50% business interruption advance within 10 business days, and payment standards backed by interest.

What I deliberately left out, with reasons in part 9: unlimited reinstatements and per-event limits, parametric downtime payments, full-limit system failure in the core, and fault-based payment reductions borrowed from German law.

1. Who the policy is for, and why

Question	Answer	Reason
Segment	U.S. businesses with \$1M–\$50M revenue	The brief asks for a small-to-mid-sized business. In my judgment this is also where standalone cyber cover is thinnest: many firms rely on a small cyber sublimit inside a business owners policy, as Cedar Ridge did (\$50,000)
Paper	Admitted, Colorado law	Small and mid-sized businesses often buy directly or through generalist agents and expect a filed, state-regulated form. Admitted paper is now common (Beazley, Cowbell, and since August 2026 Corgi's own admitted carrier), so it is a baseline rather than a selling point
Form design	One general form; each business's Declarations show what it bought	The same wording works for a dental office or a CPA firm. The Declarations, the options and the application carry the differences. The specimen's Declarations are left blank for that reason; Cedar Ridge's entries are on the application's last page
How it scales	The same wording for a 10-person shop and a 300-person firm	The retention rises with revenue (\$2,500 under \$2.5M up to \$25,000 at \$25M–\$50M) and the limit with data held, client money and contract demands (\$1M, \$2M or \$3M). Firms that need more than \$3M buy excess layers above this policy
Sample policyholder	Cedar Ridge Accounting Group (\$8.5M revenue, 62 staff: the middle of the range)	A demanding test: it holds Social Security numbers for thousands of people, moves client money, depends on cloud tax and payroll platforms, and peaks in tax season

Fit with Corgi. Corgi Insurance Company, Inc., Corgi's admitted carrier announced on August 26, 2026, targets main-street businesses including professional and administrative offices. I wrote the policy as a cyber form that carrier could file for that segment, and for startups graduating into it. Corgi's cyber page describes its startup policy as offering up to \$1M per claim and \$2M in the aggregate. I considered that two-number structure but chose a single \$2M aggregate for Cedar Ridge, because its danger is one severe event, not two average ones (part 3).

Why the first-party covers are core, not add-ons. Corgi's startup form (CORG-CY-0100, according to its cyber page) covers liability to others. Breach response, ransomware, business interruption and funds transfer fraud are sold as endorsements. That fits a software startup, whose biggest cyber exposure is often a client's claim. For a main-street business the costly events are its own losses: payment fraud, ransomware and downtime (part 2). A buyer without a broker who skips the add-ons would be uninsured for the losses most likely to happen. So this form builds them in and keeps options only for rare or systemic risks. The cost is a higher base premium and less choice item by item. I numbered it CORG-CY-0200 to sit beside the startup form.

2. How these businesses lose money

Every loss path has a coverage. Media liability (L), the smaller core coverages (G, M, N and O) and the options are explained in part 4.

#	How the money is lost	How often and how much	What it means for a firm like Cedar Ridge	Coverage
L1	Payment fraud: fake invoices, spoofed partner or client emails, bank impersonation, altered payroll batches	The most common claim type. Business email compromise and funds transfer fraud made up 58% of Coalition's 2025 claims. At-Bay's average fraud loss was \$208K for firms under \$25M revenue (\$285K across all sizes)	Cedar Ridge moves about \$2.4M a month of client payroll. One diverted batch (up to about \$210K) is a loss it would have to make good	H (and R)
L2	Ransomware: downtime, restoration, extortion	Less frequent, but the most severe: At-Bay's average ransomware claim was \$422K for firms under \$25M (\$508K across all sizes)	Cedar Ridge can run about one day without its systems in tax season. Revenue averages about \$34K per business day, more in February to April	C, D, F, A, B
L3	Data breach: notification, credit monitoring, then lawsuits and regulators	Data-breach class actions reached a record 1,822 filings in 2025. Separately, Coalition reported that privacy-rights claims, mostly website-tracking suits, doubled in the first half of 2026	About 31,000 people's records, most with Social Security numbers. Tax data breaches also trigger identity-theft follow-up with the IRS	B, I, J, K (Q for tracking suits)
L4	Vendor or cloud outage	Vendors and customers caused 14% of At-Bay's 2025 claims, averaging \$145K. In my judgment, multi-day outages of shared platforms are uncommon but severe	The outages CPA firms remember were attacks: CCH (May 2019, malware, days, with an IRS filing extension) and Kronos (December 2021, ransomware, weeks). The non-malicious version is a platform's own failure, such as Atlassian's April 2022 outage, when a maintenance script run with the wrong settings deleted customer sites and left some of its 775 affected customers offline for up to 14 days	E (attacks on vendors); P (non-malicious, optional)
L5	Own system failure: a bad update or failed server	CrowdStrike (July 2024) showed one faulty update can hit many firms at once	Usually small for a firm with tested backups	D and F, capped
L6	Regulators	Follows L3	Tax preparers are covered by the FTC Safeguards Rule and must report breaches of unencrypted data affecting 500 or more people within 30 days	J
L7	Rogue insider	Rare	An IT lead with admin rights	Attacks: built into security failure . Theft of money by the firm's own people stays with crime insurance

#	How the money is lost	How often and how much	What it means for a firm like Cedar Ridge	Coverage
L8	AI-enabled attacks: cloned voices, deepfake video calls, hijacked AI agents	Rising. Coalition said in December 2025 that deepfakes were still a small fraction of claims; so far mostly a new route to L1 and L2	Partner voice cloning to push an urgent payment in tax season	Through L1 and L2; AI-agent definitions

3. The structure: retention, limit and sublimits

The retention: what the business can absorb

Revenue band	Standard retention	About how much of a day's revenue
Under \$2.5M	\$2,500	A quarter to two-thirds of a day
\$2.5M–\$5M	\$5,000	A quarter to half a day
\$5M–\$25M	\$10,000	A tenth to half a day
\$25M–\$50M	\$25,000	An eighth to a quarter of a day

The retention does three jobs:

1. **It stays absorbable.** For Cedar Ridge, \$7,500 after its security credit is under a quarter of one day's revenue, and about 0.09% of annual revenue.
2. **It filters out small claims.** Small claims cost more to handle than they pay. Coverage A handles minor events at no cost, so the retention bites only on real incidents.
3. **It rewards the controls that stop losses.** MFA plus EDR cuts it by 25%. A 24/7 managed detection and response service cuts it by 50%. Credits don't stack; the insured gets the single best one.

The claim-free reduction (25% a year, to a floor of \$2,500) is a loyalty and security incentive. It is conditional on fixing critical issues we report, so it is kept modest.

The limit: what would sink the business

A limit should cover the worst realistic single event, then be checked for price. For Cedar Ridge that event is a tax-season ransomware attack with data theft:

Cost	Estimate
Forensics, breach coach, negotiation	\$100K–\$150K
Restoring systems and data	\$100K–\$200K
Lost income and extra expense (about 10 business days in season, after the 8-hour wait): overtime and temporary staff to catch up for up to 30 days after restoration, extension work, and fees lost during the outage	\$250K–\$450K
Notification and credit monitoring	\$100K–\$250K
Regulator defense	\$25K–\$100K

Cost	Estimate
Subtotal without a lawsuit	about \$0.6M–\$1.2M
Class action (I assume a 25–35% chance after a Social Security number breach)	+\$0.3M–\$1M
Severe total	about \$0.9M–\$2.2M

Tax-season work is mostly delayed rather than lost, so most of the lost-income line is the cost of catching up, which the policy pays as **extra expense**.

A \$1M limit covers the typical claim easily. At-Bay's average claim was \$180K for firms under \$25M revenue (\$221K across all sizes), and Coalition's average across all its policyholders was \$116K. But a \$1M limit can run out in exactly the event that would threaten the business. A \$2M limit covers all of this range except its very top, which assumes the worst case on every line at once. \$3M stays available where a client contract requires it.

I also considered Corgi's structure of \$1M per claim with a \$2M aggregate. That protects against two bad events in one year. It does not protect against one very bad event, which is the real danger for a business this size. By my estimate, raising the single-event cover to \$2M is worth \$60–150 a year in expected payments to Cedar Ridge. A second, separate \$1M is worth under \$5.

The limit rule (shown on the application's underwriter page):

- **\$1M** is the base.
- **\$2M** for businesses holding more than about 25,000 sensitive records, moving client money, or depending on a seasonal peak.
- **\$3M** where a contract requires it.

I capped this form at \$3M. Above that, businesses in this band usually need a tailored program with excess layers, which a simple rating plan shouldn't try to price.

Sublimits: where the insurer needs a narrower cap, and why

Sublimit	Amount	Reason
System failure (D and F combined)	\$250K, "applies across coverages"	Accumulation: one bad vendor update can hit many insureds at once (CrowdStrike, 2024). The label matters: in <i>CiCi Enterprises v. HSB Specialty</i> (N.D. Tex., February 2026), a court refused to apply a ransomware sublimit across coverages because the wording didn't say it did. A full-limit option is available and priced
Payment fraud (H)	\$250K core; \$500K or \$1M option (R)	Covers At-Bay's \$208K average fraud loss. Firms that move client money need more: one diversion of Cedar Ridge's largest batch (about \$210K) nearly uses the \$250K annual limit, so it buys \$500K
Fraud without a verification procedure	\$100K	Moral hazard: callback verification stops most payment fraud. It applies only if the business had no procedure or training, never when the bank was deceived, and one person's slip never triggers it
Dependent business interruption (E)	\$500K	Accumulation across shared vendors, balanced against the 14% of claims that vendors or customers caused
Dependent system failure (P, optional)	\$250K, 24-hour wait	The most systemic trigger: one vendor bug or cloud fault hits every customer at once, so it is optional, with a longer wait. It targets multi-day failures like Atlassian's in 2022, not short blips. Attacks on platforms (CCH 2019, Kronos 2021) are already covered by E
Coverage A	\$25K per incident, \$75K per year, outside the aggregate	Encourages early calls, which make losses smaller; capped so it can be priced
Bricking, reputational harm, cryptojacking	\$100K, \$100K, \$50K	Real but smaller exposures, included in the core as leading forms now do

Is \$250K enough for an accidental outage in tax season? Take the worst realistic case for Cedar Ridge: a faulty update, like CrowdStrike's in 2024, disables all 62 computers in March, and its IT provider has to fix each one by hand. My estimate:

- Two to four business days down costs \$75K–\$190K: outside technicians and restoration (\$15K–\$40K), overtime and temporary staff to catch up over the next 30 days (\$40K–\$90K), and fees lost or refunded (\$20K–\$60K).
- A full week at the peak of the season could reach \$250K–\$300K.

So the cap pays the likely case and leaves the business carrying the tail. That is the trade-off: the cap bounds the insurer's exposure to one bad update hitting every policyholder at once, and the business keeps the risk of a very long accidental outage. The full-limit option (\$400 a year for Cedar Ridge) removes the cap. Cedar Ridge did not buy it, because it has verified backups and a managed IT provider. A firm without tested backups should.

Other numbers, and why

These are judgment calls, set to be reasonable for this segment and easy to explain. An actuary would test each one.

Number	Where	Why	Alternative I rejected
8-hour waiting period (4 with 24/7 managed detection and response)	D, E	Filters out short outages a business can absorb, in line with the market. Managed detection shortens outages, so it earns a shorter wait	12 hours: would miss most of a working day, which is exactly the outage a firm this size feels
24-hour waiting period	P	Vendor outages hit many insureds at once, so only multi-day failures are covered	8 hours: would pay for short platform blips that hit every policyholder at once
180-day period of restoration, plus 30 days of catch-up costs	D, E, P	Covers a rebuild plus a full tax season. Catch-up time matters because much professional work is delayed rather than lost	90 days: too short for a rebuild that runs into tax season. 12 months: prices a longer tail than these firms face
20% coinsurance	III.1.6, 1.7	Large enough to reward the control, small enough that the business still gets 80% of a serious loss	An exclusion for missing backups: denies the very loss the policy exists for. 50%: more than most firms this size can absorb
45 days to fix a vulnerability we notify	III.1.7	About three times the two-week deadline U.S. federal agencies get for the same catalog, so a firm relying on an outside IT provider has time	14 days: fine for a government IT team, too short for a firm that waits on its IT provider's schedule
\$100K fraud limit without verification; \$5,000 verification threshold	III.6	The lower limit still pays a typical small diversion. The threshold catches almost every fraudulent wire without forcing calls on routine payments	No cover without a procedure: too harsh on a firm that simply never wrote one down. A \$10,000 threshold: misses mid-sized diversions
K \$250K; G \$25K	Item 6	Card assessments for a small merchant using a hosted payment page rarely reach six figures. \$25K buys a year of MFA, EDR and backup upgrades for a firm of 60 people	K at the full limit: adds price for a risk most hosted-payment merchants don't have
70% after a refused settlement	III.7.2	Shares the cost of a refused settlement 70/30: firmer than At-Bay's 80/20 (AB-CYB-001.2), softer than a full cap	A full cap at the refused amount: punishes an insured for a defensible refusal
\$2,500 H retention if reported within 72 hours	Item 6; III.6.3	The first 24–72 hours decide whether a bank recall works, so fast reporting earns a lower retention	No incentive: loses the one lever that improves recovery odds
14-day wait, then up to 90 days	N	Filters out a short news cycle; 90 days captures the client losses that follow a public breach	A 7-day wait: pays for noise. 12 months: can't be separated from ordinary business decline
Extended reporting: 60 days automatic; 12 or 24 months at 75% or 125%	Item 9	At-Bay's pricing, cheaper than the 100%/150%/200% in the Coalition policy I reviewed; fairer for a business closing or switching insurers	Coalition-style 100/150/200%: expensive for a firm that is closing
\$50K proof-of-loss help; \$2,500 pre-incident help	III.1.8, V.2.3	About one forensic-accountant engagement; about five to eight hours of breach-coach advice	Unlimited pre-incident advice: hard to price and easy to overuse

4. What the policy covers, and why

The coverages follow Coalition's plain "we will pay" style and At-Bay's split between first-party and liability triggers. They are grouped by what the business needs at that moment: respond to an incident (A–C), replace lost income (D–E), restore data and systems (F–G), recover stolen money (H), defend claims and investigations (I–L), and other losses (M–O). The letters stay in order so every cross-reference still works. Every coverage reads the same way: when it applies, what we pay, the limit and your share, and special conditions. The reader can answer a question about one incident from one place, and the detailed rules stay in one authoritative section.

Coverage	Loss path	Borrowed from, and what I changed	Why
A. Incident response, 7 days, outside the limit, no retention	All	The Coalition policy issued for 2025–26 (72 hours of breach response outside the limit); extended to 7 days	Email-compromise reviews often run past 72 hours. The \$25K cap per incident keeps the extra time cheap, and small cases finish without a retention
B. Breach response, including suspected events	L3	At-Bay's event definitions	Businesses shouldn't wait for proof before calling. B also pays to help people with tax-related identity theft, a real follow-on cost when tax data is stolen
C. Extortion, with "paying is never required"	L2	Coalition's consent rules; the OFAC 2021 advisory; the UK National Cyber Security Centre's 2024 guidance with the insurance associations	Without the "never required" line, a "reasonable steps to resume operations" condition could be read to push an insured to pay
D. Business interruption: attacks at full limit, system failure capped	L2, L5	The market's post-CrowdStrike distinction between malicious and non-malicious triggers (see Aon, July 2024)	Each trigger carries different accumulation risk
E. Dependent business interruption (attacks on vendors)	L4	At-Bay's external computer systems; Coalition's hosted systems	Vendors and customers caused 14% of At-Bay's 2025 claims
F. Data restoration	L2, L5	Coalition; At-Bay; Beazley BBR 5.0 added system failure	Restoration is a large part of ransomware cost
G. Security improvement costs	L2	At-Bay's post-event hardening; Coalition's betterment allowance	A small, clear budget to fix the weakness that was exploited
H. Payment fraud and invoice fraud	L1	HSB Cyber Suite's single "wrongful transfer event" trigger (deception of the insured or its bank); CFC's client-account cover; Coalition's invoice manipulation	See below
I. Privacy liability, including employees' own claims	L3	Coalition carves back employee claims; Corgi sells this by endorsement	Payroll and HR data breaches are common
J. Regulatory defense and penalties, including agencies outside the U.S.	L6	At-Bay and Coalition (core)	Breach notice deadlines of 30–60 days make regulatory scrutiny normal

Coverage	Loss path	Borrowed from, and what I changed	Why
K, L. PCI and media	L3	At-Bay, Coalition, Cowbell Prime 100 (core)	Most small and mid-sized businesses take cards and publish content
M, N, O. Bricking, reputational harm, cryptojacking (including AI-service charges)	L2, L3	Similar cover appears in the base forms of Coalition's Active Cyber Policy and Beazley BBR 5.0	Real exposures; small sublimits keep them affordable
P–T and the system-failure option	L4, L5, others	Optional	Systemic, rare or class-specific risks stay priced and visible

Why payment fraud is written this way. Fraud coverage is one of the most litigated areas of cyber and crime insurance. Three examples:

- In *Taylor & Lieberman v. Federal Insurance* (9th Cir. 2017), an accounting firm that wired a client's money after a spoofed email was denied coverage.
- In *RealPage v. National Union* (5th Cir. 2021), the insured controlled client funds but did not "hold" them.
- In *Mississippi Silicon v. AXIS* (5th Cir. 2021), an employee-authorized transfer fell to a small social-engineering sublimit.

In *Apache v. Great American* (5th Cir. 2016), a spoofed email was held "merely incidental" to an authorized transfer, so the loss did not result "directly" from computer use. Narrower wordings leave four gaps:

- only employees can be deceived, not partners;
- only the insured, not its bank;
- only accounts the insured "holds" for clients;
- a "direct result" test.

The policy's **payment fraud** definition closes all four. It covers anyone authorized to make, approve or change payments, including partners and AI agents. It covers the insured or its **financial institution** being deceived, and client accounts the firm operates. It uses "resulting from". It still requires impersonation: commercial disputes and theft by the firm's own staff stay with crime insurance. It also tells the insured to preserve its rights against the bank, since a bank must sometimes refund a fraudulent transfer.

5. What the policy limits or excludes, and why

Each restriction is tied to one or more of five reasons:

- **MH:** moral hazard;
- **ACC:** accumulation;
- **PP:** public policy or law;
- **OP:** another policy covers it;
- **NP:** can't yet be priced.

Restriction	Reason	It applies only when
20% ransomware coinsurance without verified backups	MH	Backups weren't verified, the loss is restoration or downtime from encryption, and the gap mattered. It never applies if the insured restores from its own backups anyway
20% coinsurance for a known-exploited vulnerability	MH	We warned the insured's contacts in writing, it stayed unpatched and unmitigated for 45 days, and an attacker used it. It never stacks with the ransomware coinsurance
\$100K fraud limit	MH	No verification procedure or training existed, and that mattered to the loss
System failure cap; infrastructure exclusion; war exclusion	ACC	The event is a systemic one (a vendor update, a utility or internet backbone failure, or a state-backed operation)
Intentional wrongdoing	MH	A final ruling or admission establishes it. It applies to the firm only if its top leaders took part or knew
Known problems	MH	An executive knew before the continuity date and should have expected a loss. Unexploited weaknesses, anything disclosed (unless endorsed out) and early warnings cleared before the continuity date are carved out
Sanctions; uninsurable penalties and punitive damages	PP	The law forbids payment. Colorado does not allow punitive damages to be insured, and Item 11 of the Declarations says so plainly
Professional errors (exclusion 20)	OP	A claim about the quality of accounting or tax work belongs to professional liability insurance. A breach, fraud or media claim that happens during professional work stays covered
Bodily injury, property damage, patents, employment practices, securities	OP	Another line of insurance is built for it. Breach-related emotional distress and employee privacy claims stay covered
Wrongful collection (tracking pixels) and biometric collection laws	NP	The claim is about how data was collected, not a breach. Coverage Q offers pixel cover for businesses that need it
Contract liability, claims between insureds, unsolicited communications, natural disasters, government orders, nuclear and pollution, investment losses, ill-gotten profits, the retroactive date	OP, PP, MH	Standard market exclusions. Each has a carve-back where a cyber event is the real cause (for example, contract duties to protect data, or spam sent by an attacker)

One rule for security. Section III, part 1.9 lists the only three terms that can reduce a payment because of security practices, and applies each only if the missing control caused the incident or made the loss larger. The insurer must show that link. The idea comes from the UK Insurance Act 2015 (s11), which stops an insurer relying on a risk-control term when the breach could not have mattered to the loss. I found no Colorado equivalent, so the policy supplies the rule itself.

I did not copy the German approach of cutting payment in proportion to how careless the insured was. In a Colorado form that becomes a discretionary percentage dispute, and it can't be priced.

The war exclusion. At-Bay's AB-CYB-001.2 (08/2023) form and the Coalition policy issued for 2025–26 that I reviewed still use legacy "war, hostilities, warlike operations" wording. That is the kind of language the New Jersey courts refused to apply to NotPetya in *Merck v. ACE*. The policy follows the Lloyd's Y5381 criteria and the LMA 5567 model clause, and borrows the physical-force war definition and bystander carve-back from Beazley's war and cyber war exclusion. Beazley's clause has no attribution process, so the policy uses LMA 5567's rule (attribution by the government where the affected systems are located). It takes the insurer's burden of proof and the "sovereign state" meaning from LMA 5567 and states both in plain words, adding that "state" never means a U.S. state. For small and mid-sized insureds it adds one thing the models lack: continued help while attribution is pending, with no repayment.

6. How the definitions are built

Principles:

- 1. Each definition is a plain "means" statement, in alphabetical order.
- 2. Each concept has one definition, used everywhere.
- 3. Definitions are broad where smaller businesses get hurt (rogue insiders, personal devices, paper records, deepfakes by any channel) and tight where risk accumulates (utilities, public internet infrastructure).

Definition	Choice	Why
Cloud accounts and computer systems	The accounts, tenants and data an insured controls in an online service are its own computer systems . The provider's own servers, and the hosting provider it relies on, are dependent systems	Without a clear boundary, a Microsoft 365 mailbox could be read as both, and that ambiguity cuts both ways on the most common claims. A tie-breaker treats a vendor-side attack that reaches your account as your own security failure under every coverage, and sends a vendor outage to Coverage E or P
Dependent provider	Technology providers and outsourced processors only (cloud, software, managed IT, payroll, tax filing, payment processing)	The usual market scope. Other suppliers and customers are a different risk, and a much larger accumulation. Key customers are an option (Coverage S)
Payment fraud, financial institution, client accounts	One trigger for every way an impostor tricks a firm or its bank into moving money	Part 4 above
Discover	When an executive or the named security contact becomes aware of facts suggesting an incident	Triggers, notice and exclusions all turn on this word. Leaving it undefined invites a fight over which policy year responds
Early warning	A notice from the FBI, a bank, the IT provider or us is always a suspected incident, but not by itself "discovery"	Firms without their own security team usually learn of an attack from outsiders. They shouldn't have to argue about whether an FBI call was "reasonable suspicion", and an alert that finds nothing shouldn't count against them
Related	A common cause, the same attacker's continuing access, or a causally connected series	One incident means one limit and one retention. Reports made during the policy lock in later claims
Executive	Named leaders and the designated IT or security lead, not an outside IT provider	Knowledge and exclusions should turn on the people who would actually know

Definition	Choice	Why
Security failure and system failure	A hijacked AI agent is a security failure. An AI agent that simply malfunctions is a system failure	Matches how the risk behaves, and routes each to the right limit
Public internet infrastructure	The public DNS root and top-level-domain servers, internet exchange points and backbone networks, not a provider's own systems	The October 2025 AWS outage reportedly began with a DNS fault inside AWS. Loose "internet infrastructure" wording could have excluded exactly that kind of vendor outage
Damages	Contract duties to protect data or pay for notices stay covered; punitive damages are included only where insurable	Client contracts routinely require data protection
Extra expense	Includes catch-up costs for up to 30 days after systems are restored	For professional firms the real cost of an outage is overtime and temporary staff afterwards, not lost fees

7. Underwriting and price

The application explains the price. Security questions follow the six functions of NIST CSF 2.0 and the CIS Controls v8.1 safeguards. Every starred answer maps to a credit or term on the underwriter page. I added questions underwriters now ask:

- systems past end of support;
- how the IT provider connects;
- whether backups are protected from the firm's own admins;
- IRS e-file credential protection;
- client payroll volumes;
- professional liability in force.

The application avoids traps: it asks for facts, not legal conclusions (for example, how many Colorado consumers' data the firm processes, not whether a privacy statute applies). Optional answers can't be used against the insured.

Monitoring and services. Insurtech carriers such as Coalition and At-Bay use scans and alerts both to choose risks and to prevent losses. The policy assumes the insurer scans before issue and warns about known-exploited vulnerabilities. Other services sit outside the contract. Colorado's 2025 rebate reform (SB25-058) allows value-added loss-mitigation services not specified in the policy. The policy promises that using them, or not, never reduces cover.

Premium for Cedar Ridge (illustrative):

Line	Amount
Core coverages at the \$1M base limit (about 0.07% of revenue for a professional-services risk)	\$6,120
Increase to \$2M (25% of base: most claims never reach \$1M and sublimits don't grow)	\$1,530
Coverage P, \$250K with a 24-hour wait	\$600
Coverage R, fraud limit to \$500K	\$280
10% credit for hardened remote access	-\$853
Total	\$7,677

Does it hold up against expected losses?

Expected annual loss	Low	Mid	High
Claim frequency (Coalition: 1.21% for businesses under \$25M revenue; I assume higher for firms holding tax data)	1.2%	1.5%	1.8%
Average paid claim after retention	\$110K	\$150K	\$175K
Claims within the first \$1M	\$1,320	\$2,250	\$3,150
Coverage A and pre-incident help	\$250	\$400	\$600
The second \$1M	\$60	\$100	\$150
Coverage P	\$250	\$450	\$700
Coverage R	\$20	\$45	\$80
Total expected loss	\$1,900	\$3,245	\$4,680
Expected loss ratio at \$7,677	25%	42%	61%

The second million's expected loss is only \$60–150 a year. The rest of its \$1,530 is a load for the uncertainty of severe losses, which is what reinsurers charge for. The mid case leaves room for claims handling, services, acquisition costs, a load for tax-season accumulation on Coverage P, and profit. The high case would call for a rate review. The 2026 market is soft (Marsh reported U.S. cyber rates down 2% in Q2 2026), so I did not price for rate increases. An actuary should replace this sketch with filed rates.

At \$1M with no options, the same business would pay \$5,508. The rationale for spending the extra \$2,169 is part 3's severe-event table.

Options not bought by Cedar Ridge (illustrative prices for the same firm):

Option	Price
Q. Website tracking liability (\$250K)	\$450
R at \$1M instead of \$500K	\$520 (instead of \$280)
S. Key customer interruption (\$100K)	\$300
T. Impersonation response (\$25K)	\$75
System failure full-limit option	\$400

8. How claims are paid

Promise	Why
24/7 hotline; we aim to call back within one hour	Early response shrinks losses
A call to the hotline is notice; we confirm it in writing within one business day	Some carriers say a hotline report is not notice of a claim (Chubb's cyber materials, for example), so a business that calls but never emails can miss its deadline. The written confirmation gives both sides a record
We pay vendors directly	Most businesses this size can't front forensic and legal fees mid-crisis
A 50% business interruption advance within 10 business days, up to 25% of the aggregate or the coverage's own limit, whichever is lower	Coalition's 2026 cash-advance feature is discretionary. Payroll doesn't wait for forensic accountants, so ours is firm
One forensic accountant, if the insured chooses	Two competing accountants can take months to agree
A written coverage position we aim to give within 30 days; payment within 15 days of agreement, or 8% interest compounded annually (Colorado's statutory rate) on top of any legal remedy	Only the payment promise carries a contractual remedy. The others are stated as aims, and Colorado's unfair claims practices law still applies
Free internal review, then insurer-paid mediation	A path to challenge decisions without hiring lawyers first
Late notice of incidents reduces payment only if it caused harm; claims have a firm 90-day window after expiry	Colorado enforces claims-made reporting deadlines strictly (<i>Craft v. Philadelphia Indemnity</i> , 2015), so the policy says the claims deadline is firm and makes the automatic 60-day extended reporting period cover claims first made during it
Honest application mistakes change only price, retention and credits	In <i>Travelers v. International Control Services</i> (C.D. Ill. 2022), after Travelers alleged a false MFA answer, the insured agreed to an order rescinding its policy from inception. There was no ruling on the merits, but the case shows the risk
Cancellation only for non-payment (10 days, with reasons) or a knowingly false application answer (45 days). An honest mistake never cancels the policy; at most we decline to renew	Colorado (C.R.S. 10-4-109.7) allows cancellation of a commercial policy only for non-payment, a knowingly false application statement or a substantial change in the risk, and requires 45 days' notice for all but non-payment. The policy uses only the first two
Coverage I responds even where the firm's professional liability policy might also apply	Stops a client lawsuit after a breach falling between two policies

Five claims, start to finish (Cedar Ridge):

1. **A spoofed partner email diverts a \$210K client payroll batch.** The firm calls its bank and the hotline the same day. Coverage H pays the \$210K it must repay the client, less the \$2,500 fast-report retention, within the \$500K Coverage R limit. The funds-recovery team works the bank recall. Anything recovered repays the firm's retention first.
2. **Ransomware in March; the firm restores from its own backups in six days.** Coverage A pays the hotline, breach coach and first-response forensics for the first seven days, up to \$25,000, with no retention. Forensics and the breach coach continue under B, restoration under F, and lost income under D after the 8-hour wait.

Overtime to catch up for 30 days after restoration counts as extra expense. One \$7,500 retention applies, and no coinsurance, because the backups were verified. Within 10 business days of confirming cover, the insurer advances 50% of its estimate of the business interruption loss to date.

3. **The firm's cloud tax platform pushes a bad update and is down for three days in March.** This is a non-malicious vendor failure, so optional Coverage P pays lost income and extra expense after a 24-hour wait, up to \$250K. Had it been an attack on the vendor, like CCH in 2019, core Coverage E would pay after 8 hours, up to \$500K.
4. **A client class action, eight months after a breach.** An attacker copies 31,000 client records in May. Cedar Ridge reports it at once, and Coverage B pays for notices and credit monitoring. In January, after the policy has expired, clients sue. Because the breach was reported during the policy period, the lawsuit is treated as made on that report date and is covered by this policy (Section V, part 1.4). Coverage I pays panel defense counsel and, with Cedar Ridge's consent, a \$450K settlement, within the \$2M aggregate. The \$7,500 retention paid for the breach already covers the lawsuit, because it is the same incident. Had Cedar Ridge refused a settlement the clients would accept, the policy would pay 70% of any further costs. Its accountants' professional liability policy is not a reason to delay the defense (Section V, part 9.2).
5. **A claim that is limited, and one that is declined.** - *Limited*: suppose Cedar Ridge had no written callback procedure, and a spoofed email moved a \$210K batch. The lower \$100K fraud limit would apply, because a callback to a known number would have stopped it (Section III, parts 6.2 and 1.9). Had the bank been deceived instead of the firm, the full limit would still apply. - *Declined*: a payroll clerk quietly redirects client wages to their own account. That is theft by the firm's own employee, not **payment fraud**, so Coverage H does not pay; crime insurance does. If the scheme also exposed client data, the breach costs are still covered under Coverage B.

9. Trade-offs, and what I'd test next

Considered	Decision	Why
Per-event limits (Brit C360, March 2026), unlimited reinstatements (CFC), or incident limits in place of a yearly aggregate (Emergence also revised its incident limits in its 2026 Australian small-business wording)	Declined	Uncapped frequency is hard to rate and reinsure on admitted paper. For a small or mid-sized business, one severe event is the bigger risk, so a higher single limit protects more per dollar. The cost: a firm hit twice in one year shares one \$2M limit. At an annual claim rate of 1–2%, two severe events in one year are rare
Parametric "fast downtime payment" (AIG with Parametrix, August 2026; a UK Lloyd's Market Association draft)	Declined for now; test next	For a CPA firm it would pay for downtime that is mostly deferrable, at 25–50% of the premium. Every firm on the same platform would claim at once. The firm 50% advance delivers cash speed for covered outages
Full-limit system failure in the core (Coalition's surplus-lines form)	Priced option	Accumulation. The policy is narrower than Coalition here, and says so
Deepfake and impersonation response (Coalition, December 2025)	Optional Coverage T	Real, but a small-dollar exposure. Deepfake-driven payment fraud is already covered in H
\$0 retention paths (At-Bay's MDR packages; Coalition's in-house incident response)	Credit only	The policy doesn't assume an in-house MDR service or response team; the 50% credit rewards MDR
AI regulatory defense (Beazley, September 2026)	Later	Colorado's AI law takes effect in 2027. Penalties under it are likely uninsurable
German fault-based payment cuts (VVG §28)	Declined	Not priceable, and a source of disputes under Colorado bad-faith law. The causation rule in Section III, part 1.9 takes the fair part

Where the policy is broader than the forms I compared:

- any-channel payment fraud that reaches the bank and client accounts in one trigger (HSB and CFC each cover part of this);
- a firm, not discretionary, business interruption advance;
- "paying a ransom is never required";
- a causation test for every security-based reduction;
- seven days of first response outside the limit.

Where it is narrower:

- the \$250K system-failure cap;
- optional vendor system failure;
- 70% rather than 80% on the settlement clause (At-Bay's AB-CYB-001.2 form uses 80%).

With more time I would:

- price every term against claims data with an actuary;
- confirm state rules with counsel before filing outside Colorado;
- review the war wording with reinsurers;
- test the Declarations with five owners of small and mid-sized businesses;

- measure the claims service standards against real results.

10. How I validated this

I checked the package three ways:

1. **Consistency.** I cross-checked the bold terms against the definitions, and the Declarations numbers against the wording.
2. **Law.** I checked each clause against Colorado and federal law and the cases listed below (notice, cancellation, punitive damages, fraud warnings, terrorism disclosure, rebating, and fraud and sublimit case law). A licensed Colorado coverage lawyer should review it before filing.
3. **Market.** A test of every feature against loss data and U.S. market practice, which led me to drop several features that looked good but protected little.

Regulatory status as of September 28, 2026:

Item	Status	Effect on the policy
CIRCI final rule (federal incident and ransom-payment reporting)	Not confirmed as published	The policy already lets insureds make any legally required report without consent
California SB 690 (ends private suits under California's pen-register and trap-and-trace law over website and app tracking)	Passed the Legislature unanimously on August 28, 2026; awaiting the Governor (deadline September 30, 2026). A veto looks unlikely, and in California a bill not acted on by the deadline becomes law anyway. It would take effect January 1, 2027, and would also reach pending suits	Wiretapping and other California Invasion of Privacy Act claims would remain, so Coverage Q stays
California SB 446	In effect January 1, 2026: 30-day consumer breach notice	Breach response is built around 30-day deadlines
Colorado AI law (SB 26-189)	Signed May 2026; effective January 1, 2027	AI regulatory defense deferred (part 9)
ISO generative-AI exclusions for general liability	Optional endorsements since January 2026	Affirmative AI cover is now common in cyber (Beazley, CFC). The policy's distinctive element is its AI-agent definition

Sources

Policy forms and products

- At-Bay, Cyber Insurance Policy form AB-CYB-001.2 (08/2023): <https://www.at-bay.com/wp-content/uploads/2023/06/Cyber-Insurance-Policy-Form.pdf>
- At-Bay issued cyber policy, 2025–26, publicly posted by the insured (ASTRO America): https://astroa.org/wp-content/uploads/2025/04/Corrected_Stamped_Policy___checked_4_9_25_ki_.pdf
- Coalition Cyber Policy, issued 2025–26, publicly posted by the insured: https://mwwhomelessalliance.org/wp-content/uploads/2026/02/8._Cyber-Policy.pdf
- Coalition, Active Cyber Policy FAQ (surplus lines from April 15, 2025): <https://help.coalitioninc.com/hc/en-us/articles/33998071846811-Active-Cyber-Policy-FAQ>
- Coalition, Enhanced Business Recovery (2026): <https://www.coalitioninc.com/blog/cyber-insurance/introducing-enhanced-business-recovery>
- Coalition, Deepfake Response Endorsement (December 2025): <https://www.coalitioninc.com/announcements/coalition-adds-deepfake-response-endorsement>
- Beazley, War and Cyber War Exclusion (E15626): <https://lmalloyds.com/wp-content/uploads/2025/09/Beazley-War-and-Cyber-War-Exclusion-1.pdf>
- Beazley, BBR 5.0 Enhancements and Clarifications: <https://www.beazley.com/globalassets/full-spectrum-cyber/bbr-5.0-enhancements-and-clarifications.pdf>
- HSB Cyber Suite Coverage Form CSC 02-2025: <https://heartlandmutualinsurance.com/wp-content/uploads/2024/12/Cyber-Suite-Coverage-Form-CSC-02-2025.pdf>
- Cowbell Prime 100 overview: <https://cowbell.insure/wp-content/uploads/pdfs/CB-Prime100-Overview.pdf>
- Corgi, Cyber Liability: <https://www.corgi.insure/cyber-liability>
- Sidley Austin, "California's SB 690 Clears the Legislature" (September 2026): <https://www.sidley.com/en/insights/newsupdates/2026/09/californias-sb-690-clears-the-legislature-what-it-means-for-cipa-website-tracking-claims>
- Chubb, Cyber ERM small-business sample policy (PF-48169): https://studio.chubb.com/connect/files/NA_CyberSmallBusiness_Sample.pdf
- Chubb, Cyber Alert services sheet: https://www.chubb.com/content/dam/chubb-sites/chubb-com/us-en/business-insurance/cyber-alert/documents/pdf/17-01-0219-cyber-services-sheet_cyberalert.pdf
- Insurance Business, "Emergence updates cyber policy wording for Australian SMEs" (2026): <https://www.insurancebusinessmag.com/au/news/cyber/emergence-updates-cyber-policy-wording-for-australian-smes-565467.aspx>
- Corgi Insurance Company launch (August 26, 2026): <https://www.prnewswire.com/news-releases/corgi-insurance-launches-admitted-insurance-carrier-302860246.html>
- AIG and Parametrix cloud-outage product (August 2026), Insurance Journal: <https://insurancejournal.com/news/national/2026/08/14/881539.htm>
- Brit C360 (March 2026): <https://www.britisurance.com/news/brit-launches-new-cyber-product-for-smes>

Claims and market data

- At-Bay, The 2026 InsurSec Report (April 2026), full PDF: source of the \$145K, \$180K, \$208K, \$221K, \$285K, \$422K, \$508K and 14% figures

- Coalition, 2026 Cyber Claims Report: <https://www.coalitioninc.com/claims-report/2026>
- Coalition, Understanding Why Privacy Claims Doubled in H1 2026 (July 2026): <https://www.coalitioninc.com/blog/cyber-insurance/understanding-why-privacy-claims-doubled-in-h1-2026>
- Duane Morris, Data Breach Class Action Review 2026: <https://blogs.duanemorris.com/classactiondefense/2026/02/03/hot-off-the-presses-the-duane-morris-data-breach-class-action-review-2026-and-the-duane-morris-privacy-class-action-review-2026/>
- Marsh, U.S. Insurance Market Rates Q2 2026: <https://www.marsh.com/en/services/international-placement-services/insights/us-insurance-rates.html>
- Aon, CrowdStrike event briefing (July 2024): <https://www.aon.com/en/insights/alerts/crowdstrike-and-windows-event-briefing-implications-and-initial-findings-for-cyber-reinsurers>
- Accounting Today, The Wolters Kluwer CCH outage (2019): <https://www.accountingtoday.com/news/the-wolters-kluwer-cch-outage-what-happened>
- Accounting Today, IRS approves extensions for returns hit by CCH outage (2019): <https://www.accountingtoday.com/news/irs-approves-extensions-for-returns-hit-by-cch-outage>
- Atlassian, Post-incident review of the April 2022 outage: <https://www.atlassian.com/blog/atlassian-engineering/post-incident-review-april-2022-outage>
- CFC, Cyber product enhancements: cybercrime (March 2025): <https://www.cfc.com/en-us/knowledge/resources/articles/2025/03/cyber-product-enhancements-cybercrime/>
- CFC, Unlimited reinstatements (July 2024): <https://www.cfc.com/en-us/knowledge/resources/articles/2024/07/cyber-coverage-highlights-unlimited-reinstatements/>
- HR Dive, Kronos outage (December 2021): <https://www.hrdive.com/news/all-hands-on-deck-for-hr-teams-as-kronos-outage-drag-on/611811/>

Law and regulation

- NIST Cybersecurity Framework 2.0 (2024): <https://www.nist.gov/cyberframework>
- CIS Critical Security Controls v8.1 (2024): <https://www.cisecurity.org/controls/v8-1>
- U.S. Treasury OFAC, ransomware advisory (September 21, 2021): <https://ofac.treasury.gov/media/912981/download>
- FTC Safeguards Rule, 16 CFR Part 314: <https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314>
- UK National Cyber Security Centre, Guidance for organisations considering payment in ransomware incidents (May 2024): <https://www.ncsc.gov.uk/guidance/organisations-considering-payment-in-ransomware-incidents>
- UK Insurance Act 2015, section 11: <https://www.legislation.gov.uk/ukpga/2015/4/section/11>
- Lloyd's Market Bulletin Y5381, state-backed cyber-attack exclusions (August 16, 2022)
- U.S. Treasury, guidance on stand-alone cyber policies under the Terrorism Risk Insurance Program (December 27, 2016)
- Colorado SB25-058, insurance rebate reform: <https://leg.colorado.gov/bills/sb25-058>
- Colorado statutes: C.R.S. 10-4-109.7 (cancellation notice), 10-1-128 (fraud warning), 5-12-102 (interest), 10-3-1115/1116 (unreasonable delay or denial)

Cases

- *Merck & Co. v. ACE American Insurance Co.*, 475 N.J. Super. 420 (App. Div. 2023)
- *Travelers Property Casualty Co. v. International Control Services*, No. 22-cv-2145 (C.D. Ill. 2022)

- *CiCi Enterprises v. HSB Specialty Insurance Co.* (N.D. Tex. February 23, 2026), summary: <https://www.mondaq.com/unitedstates/insurance-laws-and-products/1770926/court-rejects-insurers-attempt-to-cap-cyber-extortion-coverage-based-on-ransomware-sub-limit>
- *Taylor & Lieberman v. Federal Insurance Co.* (9th Cir. 2017)
- *RealPage, Inc. v. National Union Fire Insurance Co.* (5th Cir. 2021)
- *Mississippi Silicon Holdings v. AXIS Insurance Co.* (5th Cir. 2021)
- *Apache Corp. v. Great American Insurance Co.*, 662 F. App'x 252 (5th Cir. 2016)
- *Craft v. Philadelphia Indemnity Insurance Co.*, 2015 CO 11
- *Lira v. Shelter Insurance Co.*, 913 P.2d 514 (Colo. 1996) (punitive damages not insurable): <https://law.justia.com/cases/colorado/supreme-court/1996/95sc153-0.html>